

Security and Access Document (SAD)

CampusFind Pro - Data Security, API Key Management, and Access Safeguards

1. Authentication and Profile Sync

Secure user authentication is managed via Google OAuth 2.0. The auth callback (auth/google-callback.php) validates token exchanges securely with Google, creating a local session mapping. A remote profile avatar sync checks if the user has a broken local avatar filename (such as old files generated on localhost) and automatically repairs the record in the database, updating it to their live remote Google picture URL.

2. Request & Session Protections

- **CSRF Defense:** State-changing actions generate cryptographically secure CSRF tokens stored in the session. All POST requests are verified against these tokens to prevent cross-site request forgery.
- **SQL & NoSQL Injection Prevention:** All database queries avoid string concatenation and rely on MongoDB's query arrays. Type casting ensures that ID fields only accept BSON ObjectIds.
- **Role-based Routing:** Pages verify session roles using `requireRole('student')` or `requireRole('admin')` routing filters before delivering layouts, immediately redirecting violators.

3. External API Credentials Management

Sensitive credentials (such as Google secrets, DB connection strings, and Brevo mailer keys) are stored in local `.env` files ignored by Git, preventing source leaks. On production hosts, keys are bound to Render environment variables, loaded safely via `getenv()`.